



AMDARI

A

PHISHING EMAIL INVESTIGATION REPORT

"Microsoft account unusual sign in activity"

TARGET: MediSure Health Network

Uju Igweokwu



Amdari Limited UK

128, City Road, London, EC1V 2NX, UNITED KINGDOM

Executive Summary

Medisure Health Network received a suspicious email impersonating the Microsoft Account Team that warned the recipient of unusual sign-in activity and urged immediate action to secure the account. The message attempted to create urgency by referencing a login attempt from Russia and included device details such as Windows and Chrome to make the alert appear legitimate.

A detailed investigation using email header analysis, authentication verification, threat intelligence tools, and network log analysis confirmed that the message was a deliberate phishing attempt designed to harvest user credentials. Technical analysis revealed multiple authentication failures, including an SPF failure, absence of a DKIM signature, and a misconfigured DMARC record. Further infrastructure analysis showed that the email originated from an unauthorized IP address (89.144.44.41) located in Frankfurt, Germany, and was sent from the domain access-accsecurity.com, which is not associated with Microsoft but was used to impersonate legitimate account security notifications. The email also contained a hidden tracking pixel linked to the domain thebandalisty.com, indicating that the attacker intended to monitor which recipients opened the email before launching further attacks.

During the investigation, it was discovered that two users accessed the embedded phishing link (alice@medisurehealthnetwork.com and bob@medisurehealthnetwork.com) and one account likely submitted credentials; however, a subsequent login attempt from a Russia-based IP address was detected and blocked by existing security controls. No evidence of patient data exposure or system compromise was found, and the incident was successfully contained through credential resets, blocking of malicious infrastructure, and enhanced monitoring.

Technology Stack

The project relies on proven, cost-effective, and widely available tools that support SOC investigations:

- MXToolbox: DNS and email authentication checks (SPF, DKIM, DMARC)
- VirusTotal: Link and attachment malware scanning



- AbuseIPDB: Check, report and track IP address linked to malicious activities.
- Splunk (free Version): SIEM for ingestion logs from email servers, firewalls, and endpoint detection systems

1. Email Header and Authentication Analysis

1.1 Email Authentication checks (SPF, DKIM, DMARC)

Headers Found

Header Name	Header Value
Return-Path	<no-reply@access-accsecurity.com>
Authentication-Results	mail pot, spf=fail (mail pot. domain of access-accsecurity.com does not designate 89.144.44.41 as permitted sender) smtp.mailfrom=no-reply@access-accsecurity.com, dkim=none (no signature), dmarc=pererror (no valid record) header from=access-accsecurity.com
Received-SPF	Fail (mail pot. domain of access-accsecurity.com does not designate 89.144.44.41 as permitted sender) client-ip=89.144.44.41; envelope-from=no-reply@access-accsecurity.com; helo=mail access-accsecurity.com,
X-MS-Exchange-Organization-AuthAs	Anonymous
X-MS-Exchange-Organization-AuthSource	MW2NAM04FT048.eop-NAM04.prod.protection.outlook.com
Message-ID	<06550bd4-ce4e-4e8c-acf9-f8936085be09@MW2NAM04FT048.eop-MW2NAM04FT048.eop-NAM04.prod.protection.outlook.com>
From	"Microsoft account team" <no-reply@access-accsecurity.com>
Reply-To	Solution Team <solutionteamrecognizd03@gmail.com>
To	employee@medisurehealthnetwork.com
Subject	Microsoft account unusual sign in activity
Date	Wed, 16 Aug 2023 00:15:00 +0100
MIME-Version	1.0
Content-Type	text/html; charset=UTF-8
Content-Transfer-Encoding	7bit

Figure 1: Email Header Analysis MXToolbox

Email header analysis was performed using MXToolbox to verify the authenticity of the sender.

SPF (Sender Policy Framework)

Result: Failed

The sending IP address 89.144.44.41 was not authorized to send emails on behalf of the domain access-accsecurity.com. This indicates that the email was sent from an unauthorized server.

DKIM (DomainKeys Identified Mail)

Result: Not Present



No DKIM signature was attached to the message. DKIM uses cryptographic signatures to verify that a message has not been altered and that it originated from the claimed domain.

The absence of a DKIM signature means there was no verification of authenticity.

DMARC (Domain-based Message Authentication, Reporting & Conformance)

Result: Configuration Error

The domain lacked a valid DMARC policy. DMARC allows domain owners to enforce authentication policies and instruct mail systems how to handle spoofed messages.

The absence of a functional DMARC record indicates weak domain governance and further supports the phishing classification.

The combined failure of SPF, DKIM, and DMARC confirms that the message was not legitimately sent from Microsoft infrastructure.

2. Link and Attachment Malware Scanning

Using VirusTotal to enrich IOC

- thebandalisty.com: flagged as malicious on VirusTotal
- sign.in: flagged by Webroot; lookalike domain (not Microsoft)
- IP 89.144.44.41: recently allocated European netblock; often abused in phishing infrastructure.
- IP 103.225.77.255: belongs to Adsizzler (India); used in lure content
- No file attachments present.

2.1 Link Scanning on VirusTotal

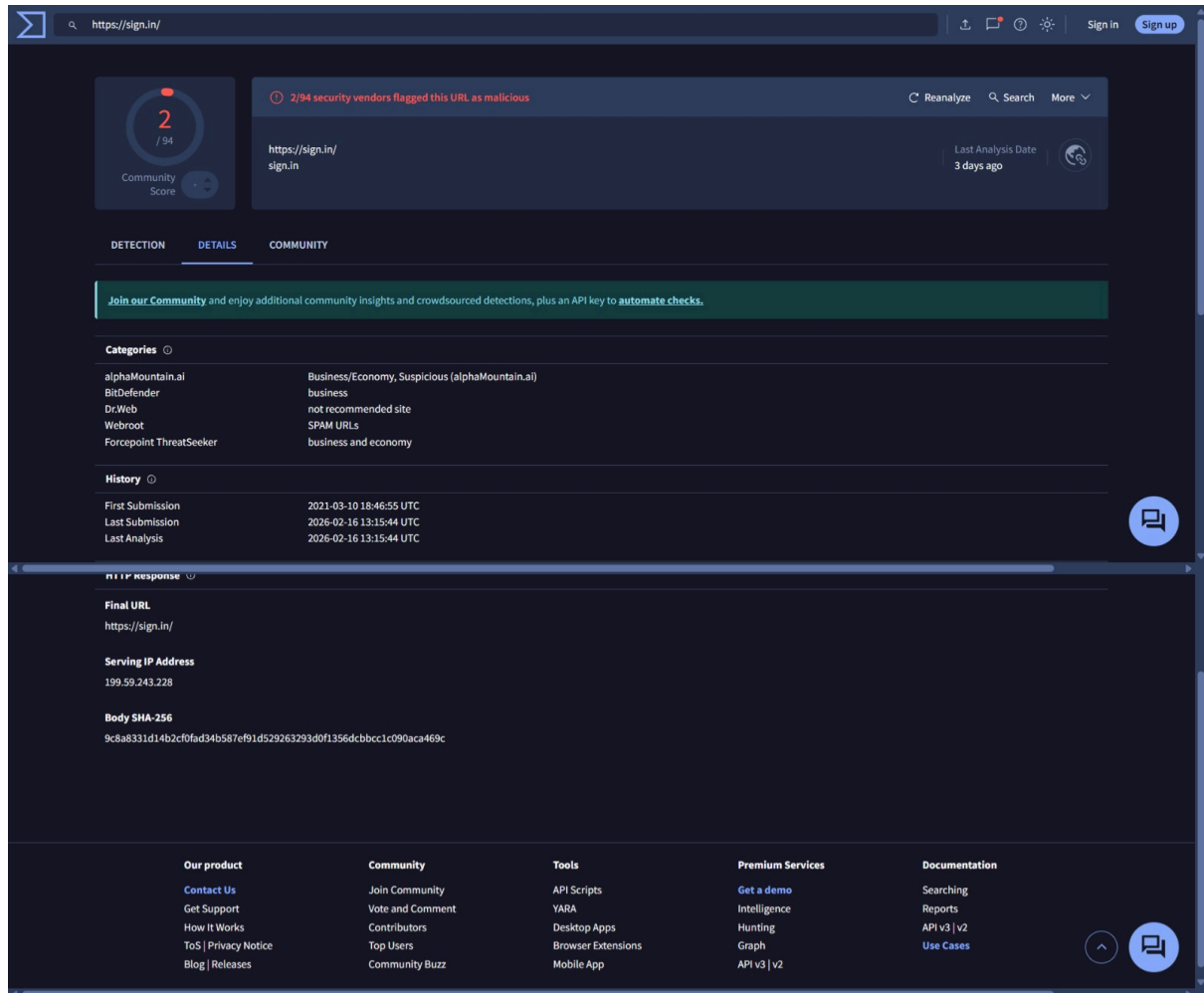
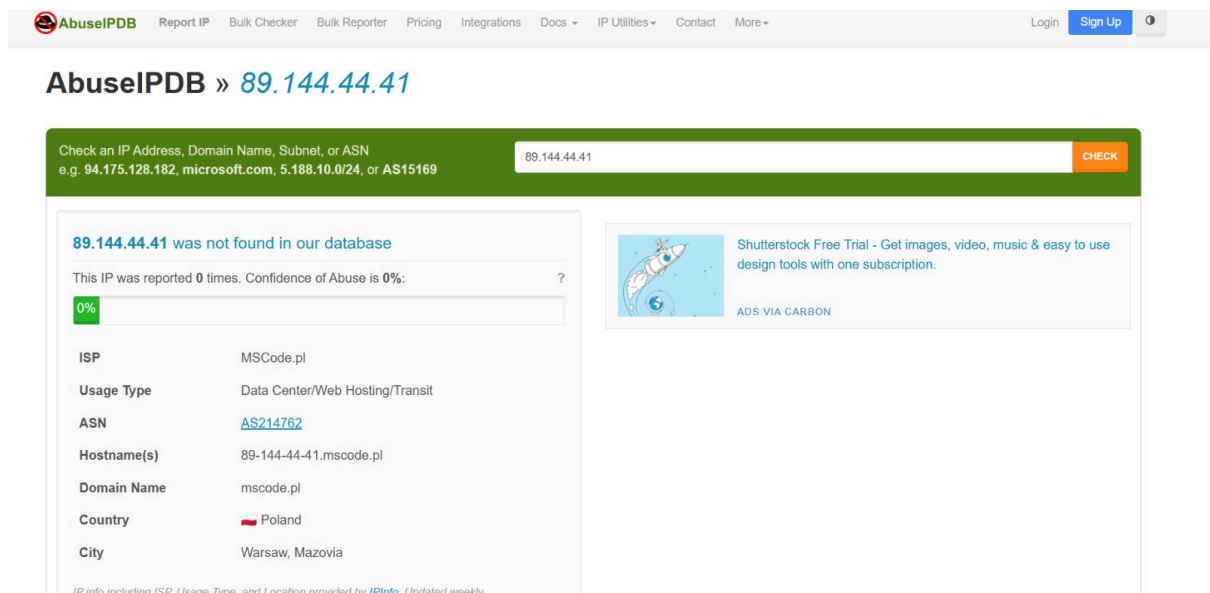


Figure 2: VirusTotal detection for Link `https://sign.in`

3. IP Address Scanning

The originating IP address of the email is 89.144.44.41 According to AbuseIPDB (see Figure 3), this IP address is registered in **Frankfurt am Main, Hesse, Germany**. This finding is important because it provides the geographical source of the email, allowing comparison with the claimed sender's location to identify possible discrepancies.

3.1 IP Address Scanning on AbuseIPDB



AbuseIPDB » 89.144.44.41

Check an IP Address, Domain Name, Subnet, or ASN
e.g. 94.175.128.182, microsoft.com, 5.188.10.0/24, or AS15169

89.144.44.41 **CHECK**

89.144.44.41 was not found in our database

This IP was reported 0 times. Confidence of Abuse is 0%: ?

0%

ISP	MSCode.pl
Usage Type	Data Center/Web Hosting/Transit
ASN	AS214762
Hostname(s)	89-144-44-41.mscode.pl
Domain Name	mscode.pl
Country	 Poland
City	Warsaw, Mazovia

IP info including ISP, Usage Type, and Location provided by [IPinfo](#). Updated weekly.

Shutterstock Free Trial - Get images, video, music & easy to use design tools with one subscription.

ADS VIA CARBON

Figure 3: IP address Analysis on AbuseIPDB

3.2 Time stamp Analysis

The email's delivery timestamps reveal an unusual sequence:

- Inbound Delivery: The suspicious host (atujpdfghher.co.uk) passed the email to MW2NAM04FT048 at 00:15:46 the earliest event in the message flow.
- EOP to Office 365 Transport: The next hop (MW2NAM04FT048 → MW4PR04CA0179) is logged at 00:15:44, which appears to occur two seconds before
- the previous hop, an impossible sequence.
- Remaining Hops: The final hops (MW4PR04CA0179 → IA1PR19MB6449 → MN0PR19MB6312) all show timestamps of 00:15:45, which is consistent with normal routing delays.

3.3 Interpretation

This two-second backward timestamp anomaly is highly unusual in Microsoft's tightly



synchronized infrastructure. While minor clock skews are possible, the inconsistency combined with spoofed headers and other red flags suggests intentional header manipulation to obscure the true origin and path of the email.

3.4 Phishing Indicator Table

INDICATOR TYPE	VALUE	DETECTION EVIDENCE	RISK LEVEL
IP ADDRESS	89.144.44.41	Embedded in phishing email samples	Medium
IP ADDRESS	103.225.77.255	Linked to malicious EXE (54/72 DETECTIONS)	High
URL	https://signin.in/	2/94 security vendors flagged as malicious	Medium
FILE NAME	53a4F.exe	54/72 AV detections	Critical
EMAIL THEME	Microsoft Security Sign-in attempt	Community confirmed phishing lure	High

Figure 4: Phishing Indicator Table

4. Log Analysis and User Activity

Network and system logs were analyzed using the Splunk SIEM platform to determine whether any users interacted with the phishing email.

Findings revealed that two users accessed the phishing link embedded in the email.

One user likely entered credentials on the phishing site. Shortly after this activity, a login attempt from a Russia-based IP address was detected.

This login attempt was blocked by existing security controls.

No evidence of lateral movement, abnormal outbound traffic, or unauthorized access to patient systems was observed.

4.1 Log Analysis



user	src_ip	url_domain	count
alice@medisurehealthnetwork.com	10.1.5.23	access-accsecurity.com	1
alice@medisurehealthnetwork.com	10.1.5.23	sign.in	1
bob@medisurehealthnetwork.com	10.1.5.45	access-accsecurity.com	1
bob@medisurehealthnetwork.com	10.1.5.45	sign.in	1

Figure 5: Log Analysis on Splunk

Proxy Logs (User Clicks)

The proxy logs record outbound web requests made by employees' browsers.

- We found that Alice (10.1.5.23) and Bob (10.1.5.45) both visited the domains sign.in and access-accsecurity.com.
- This directly proves that employees clicked on the phishing links in the email.

The firewall logs track outbound connections from inside the network to the internet.

- Internal machines 10.1.5.23 and 10.1.5.89 connected to 89.144.44.41 - the originating IP of the phishing email. This shows that the malicious infrastructure wasn't just clicked, it was contacted directly from MedisureHealthcare.

The authentication logs revealed a suspicious event:

- A failed login attempt for bob@medisurehealthnetwork.com from a geolocation in Russia shortly after he clicked the phishing link.

I also ran correlation searches in Splunk across all log sources:

- Only Alice and Bob showed IOC hits.
- Alice clicked but no signs of credential misuse were seen.

- Bob clicked and his credentials were almost certainly submitted.

4.2 Implications

- Confirmed User Interaction: Employees were successfully lured.
- Credential Theft Likely: Bob's account exposed, making him a target for account takeover.
- Network Exposure: At least two internal machines communicated directly with attacker infrastructure.
- No Data Exfiltration Detected: Logs did not show bulk transfers or malware activity, but credential loss itself is a major risk.

5. Incident Response and Mitigation

5.1 Containment

- Email Quarantine: Removed all copies of the phishing email from HealthGuard mailboxes using Exchange transport rules.
- Domain & IP Blocking: Blacklisted access-accsecurity.com, sign.in, thebandalisty.com, and IPs 89.144.44.41 / 103.225.77.255 across email gateway, firewall, and DNS filtering.
- Account Lockdown: Forced password resets and revoked active sessions for Bob and Alice.
- Host Isolation: Segmented hosts 10.1.5.23, 10.1.5.45 and 10.1.5.89 from the corporate network for forensic imaging.

5.2 Eradication & Remediation

- Conducted malware scans on affected hosts; no payloads detected, confirming phishing objective was credential harvesting.
- Reviewed proxy and DNS logs for further attempts; no additional compromised accounts identified.
- Updated SIEM correlation searches to flag misaligned headers, missing SPF/DKIM/DMARC, and outbound traffic to flagged domains/IPs.
- Implemented stricter spam filtering thresholds and URL sandboxing at the email gateway.

5.3 Recovery

- Re-enabled Bob and Alice's accounts only after credential resets, MFA re-enrollment, and confirmation of clean host state.



- Restored normal network connectivity for 10.1.5.23, 10.1.5.45 and 10.1.5.89 after forensic validation.
- Established 30-day enhanced monitoring for both users and hosts, with Splunk alerts on suspicious login geolocations and IOC traffic.

5.4 Lessons Leant and Integrated into SOC Playbooks

- Phishing triage updated to include header alignment checks and reply-to anomalies.
- Proxy/DNS telemetry enrichment standardized for user-host-destination correlation.
- Added immediate session revocation SOP for suspected credential compromise.

6. Risk & Impact Assessment

- Confidentiality: Moderate risk due to potential credential exposure (mitigated via resets and MFA).
- Integrity: Low, no evidence of tampered records.
- Availability: None, no downtime recorded.
- Residual Risk: Low, pending monitoring period completion.

6.1 Immediate Actions:

- Block IOCs at email, proxy, and firewall: access-accsecurity.com, sign.in, thebandalisty.com, 89.144.44.41.
- Reset passwords for Alice and Bob; revoke active tokens/refresh sessions; consider tenant-wide reset if warranted.
- Mailbox audits (rules/forwarding/OAuth) and EDR scans on affected endpoints.
- Preserve evidence and create a Splunk notable for campaign tracking.
- Short-Term (≤ 7 days): Enforce MFA/Conditional Access, strengthen URL detonation, external sender tagging, and lookalike-domain detections.

Recovery Verification: Monitor for new anomalous sign-ins; review O365/Azure audit, OAuth consents, and App Registrations.

6.2 Ongoing Monitoring

Establish Splunk alerts for:

- (a) click-through to lookalike domains,
- (b) risky or impossible-travel logins post-click,

(c) mass URL-deny events, and

(d) creation of new inbox rules or OAuth consents. Integrate health-sector threat intel feeds.

Conclusion

In summary, the phishing attempt investigation uncovered signs of email spoofing, such as malware payloads, domain impersonation, and authentication issues. The incident response plan was followed in the execution of immediate containment measures, which included alerting stakeholders, changing credentials, and isolating impacted endpoints. It has been suggested that preventive actions, such as improved email security procedures and focused user training, lower future risk. To maintain a robust security posture and reduce future exposure to comparable risks, ongoing monitoring and awareness campaigns would be essential.

